

AUTOMATED ACCESS CONTROL SECURITY TEST REPORT

Target: Live Website • http://127.0.0.1:3000

RBAC • JWT • Vertical Authorization • Horizontal Authorization / IDOR • JWT Validation

Generated: 28 September 2026, 11:52:37

TOTAL	PASSED	FAILED	STATUS
34	3	8	X FAIL

SECURITY TEST CATEGORIES

CATEGORY	TOTAL	PASSED	FAILED
Authentication	8	1	7
Authorization	8	2	6
Horizontal Authorization / IDOR	9	0	9

DETAILED SECURITY TEST RESULTS

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-001	GUEST	Authorization	GET	/	allow	200	200	✓ PASS
AC-002	GUEST	Authentication	POST	/api/login	allow	200	500	X FAIL
AC-003	GUEST	Authorization	GET	/api/products	allow	200	200	✓ PASS
AC-004	USER	Authorization	GET	/	allow	200	None	X FAIL
AC-005	USER	Authentication	POST	/api/login	allow	200	None	X FAIL
AC-006	USER	Authorization	GET	/api/products	allow	200	None	X FAIL
AC-007	USER	Authorization	GET	/api/me	allow	200	None	X FAIL
AC-008	USER	Horizontal Authorization / IDOR	GET	/api/users/	own	200	None	X FAIL
AC-009	USER	Horizontal Authorization / IDOR	GET	/api/orders/	own	200	None	X FAIL
AC-010	USER	Vertical Authorization	GET	/api/admin/users	deny	403	None	X FAIL
AC-011	USER	Vertical Authorization	DELETE	/api/admin/users/	deny	403	None	X FAIL
AC-012	USER	Vertical Authorization	GET	/api/admin/stats	deny	403	None	X FAIL
AC-013	USER	Horizontal Authorization / IDOR	PATCH	/api/users/	own	200	None	X FAIL
AC-014	ADMIN	Authorization	GET	/	allow	200	None	X FAIL
AC-015	ADMIN	Authentication	POST	/api/login	allow	200	None	X FAIL
AC-016	ADMIN	Authorization	GET	/api/products	allow	200	None	X FAIL
AC-017	ADMIN	Authorization	GET	/api/me	allow	200	None	X FAIL
AC-018	ADMIN	Horizontal Authorization / IDOR	GET	/api/users/	any	200	None	X FAIL
AC-019	ADMIN	Horizontal Authorization / IDOR	GET	/api/orders/	any	200	None	X FAIL

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-020	ADMIN	Vertical Authorization	GET	/api/admin/users	allow	200	None	X FAIL
AC-021	ADMIN	Vertical Authorization	DELETE	/api/admin/users/	allow	200	None	X FAIL
AC-022	ADMIN	Vertical Authorization	GET	/api/admin/stats	allow	200	None	X FAIL
AC-023	ADMIN	Horizontal Authorization / IDOR	PATCH	/api/users/	any	200	None	X FAIL
AC-024	GUEST	Authentication	GET	/api/me	unauthenticated	401	500	X FAIL
AC-025	GUEST	Authentication	GET	/api/admin/users	unauthenticated	401	500	X FAIL
AC-026	GUEST	Authentication	GET	/api/admin/stats	unauthenticated	401	500	X FAIL
AC-027	GUEST	Authentication	GET	/api/users/2	unauthenticated	401	401	✓ PASS
AC-028	GUEST	Authentication	GET	/api/orders/101	unauthenticated	401	500	X FAIL
AC-029	USER	JWT Validation	GET	/api/me	invalid_token	401	500	X FAIL
AC-030	USER	JWT Validation	GET	/api/admin/users	invalid_token	401	500	X FAIL
AC-031	USER	JWT Validation	GET	/api/admin/stats	invalid_token	401	500	X FAIL
AC-032	USER	Horizontal Authorization / IDOR	GET	/api/users/	deny	403	None	X FAIL
AC-033	USER	Horizontal Authorization / IDOR	PATCH	/api/users/	deny	403	None	X FAIL
AC-034	USER	Horizontal Authorization / IDOR	GET	/api/orders/	deny	403	None	X FAIL

X OVERALL SECURITY RESULT: FAIL

34 automated security tests were executed. 3 passed and 8 failed.

Review the failed authorization, authentication, JWT, or IDOR tests.